PARCIAL II Y RÚBRICA DE EVALUACIÓN EXPOSICIONES PRÁCTICAS EN AUDITORÍA EN SEGURIDAD DE LA INFORMACIÓN

Curso: Auditoría en Seguridad de la Información
Norma Técnica Base: NTC-ISO-IEC 27001:2022
Duración Máxima por Equipo: aproximadamente 60 minutos
Fecha de Inicio: Jueves 29 de octubre (Modalidad Virtual)
Naturaleza del ejercicio: Simulación académica de auditoría técnica de seguridad de la información, con alcance definido, muestreo justificado, pruebas controladas y evidencias verificables.

1. OBJETIVO DE LA ACTIVIDAD

- Desarrollar una auditoría técnica de seguridad de la información, de alcance delimitado y basada en muestreo, mediante la evaluación de requisitos y controles aplicables de NTC-ISO/IEC 27001:2022.
- Al finalizar, cada equipo entregará un expediente de auditoría trazable y defenderá individualmente sus conclusiones. No se evalúa la cantidad de herramientas ejecutadas, sino la calidad de los criterios, pruebas, evidencias y razonamiento.

2. LA REGLA DE ORO: LA PARADOJA DEL AUDITOR

2.1. Principio de independencia, objetividad

- En una auditoría empresarial, el auditor debe actuar con imparcialidad, objetividad, integridad y debido cuidado profesional. Su responsabilidad consiste en obtener y evaluar evidencia objetiva frente a criterios previamente establecidos, con el fin de determinar el grado de cumplimiento de los requisitos aplicables.
- El auditor no debe fabricar, alterar, ocultar ni presentar evidencias artificiales como si correspondieran a operaciones reales de la organización. Tampoco debe asumir responsabilidades de implementación o gestión que comprometan su independencia.

2.2. Excepción pedagógica: preparación del laboratorio y simulación de auditoría

Para esta actividad académica, cada equipo desarrollará dos fases claramente diferenciadas:

- **Fase de preparación del entorno:** Los estudiantes actuarán como responsables técnicos del laboratorio. Podrán configurar sistemas, establecer controles, preparar cuentas, crear escenarios de funcionamiento correcto y simular debilidades de seguridad, siempre en entornos autorizados y controlados.

- **Fase de auditoría:** Los estudiantes asumirán el rol de auditores técnicos. Evaluarán los escenarios mediante criterios definidos previamente, ejecutarán pruebas autorizadas, recopilarán evidencias, analizarán resultados y sustentarán sus conclusiones.
- La preparación de escenarios no autoriza a fabricar resultados ni a declarar anticipadamente conformidades o no conformidades. El dictamen deberá derivarse de las evidencias obtenidas durante la verificación.

2.3. Regla fundamental

- Ningún hallazgo podrá sustentarse exclusivamente en una afirmación del estudiante, una captura aislada o un resultado automático de una herramienta sin interpretación.
- Toda conclusión deberá relacionar, como mínimo:
    - **Criterio de auditoría → elemento evaluado → procedimiento ejecutado → evidencia objetiva → resultado → análisis → conclusión.**

3. METODOLOGÍA: AUDITORÍA POR MUESTREO Y ESCENARIOS PACTADOS

1. Selección y justificación de la muestra

- Cada equipo deberá identificar la población total de elementos relacionados con los controles que serán evaluados y seleccionar una muestra concreta, delimitada y técnicamente justificada.
- La selección deberá considerar, según corresponda, la criticidad para el negocio, la sensibilidad de la información, la exposición a amenazas, los privilegios de acceso, las funciones desempeñadas, los riesgos identificados y las características del control objeto de auditoría.
- No será suficiente indicar cuántos elementos se van a evaluar. El equipo deberá explicar por qué seleccionó esos elementos y qué permite comprobar su evaluación.

⚠ **Importante:** Precisión técnica: La herramienta no determina automáticamente si existe una no conformidad ISO 27001. Por ejemplo, una alerta de Semgrep puede requerir validación para descartar un falso positivo. El auditor debe relacionar el resultado confirmado con el requisito aplicable, las reglas de la organización y el riesgo identificado.

Ejemplo tabla 1: empresa de desarrollo de software a la medida con cinco repositorios inventariados. Se seleccionan dos: R-01 (aplicación de historias clínicas) y R-02 (API de identidad y autorizaciones). Los riesgos y clasificaciones son supuestos que deberán confirmarse en una auditoría real.

Tabla 1

Campo de planificación	Determinación y justificación empresarial
Proceso y objetivo	Desarrollo, mantenimiento y protección del código fuente. Comprobar controles aplicables de acceso, desarrollo seguro, pruebas y cambios.
Población y unidad	5 repositorios de código fuente registrados; unidad de muestreo: repositorio y, para pruebas específicas, cuenta, rama, solicitud de integración o cambio.
Muestra y cobertura	2 repositorios (40 % de la población por cantidad, sin representatividad estadística): R-01 Historias clínicas y R-02 API de identidad.
Criterios de selección	Criticidad de servicios; sensibilidad de datos; superficie de exposición; alcance de privilegios; dependencia de otros sistemas; cambios y vulnerabilidades conocidas.
Justificación técnica y empresarial	El software soporta el tratamiento de datos de salud, con potencial impacto legal, operativo y reputacional ante exposición, modificación o indisponibilidad. Se prioriza por confidencialidad e integridad de información sensible y necesidad de trazabilidad de cambios. La API participa en autenticación y autorización de usuarios; fallas de lógica o secretos expuestos pueden facilitar accesos indebidos, escalamiento de privilegios y afectación transversal a aplicaciones dependientes.
Controles a evaluar	A.8.4 acceso al código fuente; A.8.25 ciclo de vida de desarrollo seguro; A.8.26 requisitos de seguridad de aplicaciones; A.8.28 codificación segura; A.8.29 pruebas de seguridad; A.8.32 gestión de cambios. A.5.18 y A.8.8 cuando resulten aplicables.

<table>
<tr><th>Campo de planificación</th><th>Determinación y justificación empresarial</th></tr>
<tr><td>Procedimientos previstos</td><td>
1. Cruzar el inventario de activos y la clasificación de criticidad con la Declaración de Aplicabilidad (SoA), las políticas y los procedimientos de desarrollo seguro;
2. verificar los permisos efectivos de acceso a los repositorios;
3. inspeccionar la configuración de protección de ramas;
4. seleccionar una muestra de cambios y comprobar sus aprobaciones y trazabilidad;
5. revisar los mecanismos de protección de secretos;
6. examinar los resultados de análisis estático de código (SAST) y análisis de composición de software (SCA), así como el tratamiento de las vulnerabilidades identificadas.
7. Adicionalmente, ejecutar como mínimo una prueba técnica controlada mediante una herramienta especializada de seguridad, seleccionada de acuerdo con el objetivo y el control auditado, sobre uno o ambos repositorios incluidos en la muestra. El equipo deberá documentar la herramienta utilizada, su versión, el objetivo de la prueba, el alcance autorizado, los parámetros de ejecución, los resultados obtenidos, la validación de los hallazgos y las evidencias generadas.
Aclaración: La prueba deberá permitir contrastar el resultado técnico con un criterio de aceptación previamente establecido y sustentar una conclusión sobre la implementación, operación o eficacia del control evaluado, según corresponda. No se aceptará como prueba suficiente la simple presentación de una captura de pantalla o de un reporte sin interpretación técnica.

HERRAMIENTAS:
<table>
<tr><th>Herramienta</th><th>Prueba que puede ejecutar el estudiante</th><th>Control ISO/IEC 27001:2022 relacionado</th><th>Evidencia esperada</th></tr>
<tr><td>Semgrep</td><td>Ejecutar un análisis SAST sobre un repositorio seleccionado para identificar patrones de codificación potencialmente inseguros.</td><td>A.8.28 — Codificación segura</td><td>Comando, reglas aplicadas, versión, reporte, análisis de resultados y validación de hallazgos.</td></tr>
<tr><td>Gitleaks</td><td>Analizar el repositorio para detectar posibles contraseñas, tokens o claves expuestas en el código o historial.</td><td>A.8.4 — Acceso al código fuente; A.8.28 — Codificación segura</td><td>Reporte de hallazgos, archivos afectados con datos sensibles ocultos y evidencia del tratamiento.</td></tr>
<tr><td>OWASP Dependency-Check</td><td>Identificar dependencias con vulnerabilidades conocidas en una aplicación.</td><td>A.8.8 — Gestión de vulnerabilidades técnicas</td><td>Reporte de dependencias, vulnerabilidades identificadas, análisis de aplicabilidad y tratamiento.</td></tr>
<tr><td>SonarQube</td><td>Analizar el código y revisar hallazgos de seguridad, reglas y resultados del proyecto.</td><td>A.8.28 — Codificación segura</td><td>Resultado del análisis, configuración de reglas, hallazgos y trazabilidad de revisión.</td></tr>
<tr><td>OWASP ZAP</td><td>Realizar pruebas controladas sobre una aplicación desplegada en laboratorio, asociada al repositorio auditado.</td><td>A.8.29 — Pruebas de seguridad en desarrollo y aceptación</td><td>Alcance autorizado, configuración, reporte, verificación de hallazgos y conclusión.</td></tr>
</table>
</td></tr>
<tr><td>Evidencias esperadas</td><td>Inventario; clasificación; matriz de riesgos; SoA si existe SGSI; roles y permisos; reglas de protección; PR/MR y aprobaciones; bitácoras; reportes SAST/SCA; tickets; registros de pruebas; capturas con metadatos y referencias.</td></tr>
<tr><td>Criterios de aceptación</td><td>Los criterios se derivan de políticas, requisitos aplicables y procedimientos aprobados; se expresan por prueba (p. ej., cambios a rama principal requieren aprobación según política). No se presupone que una herramienta concreta sea obligatoria.</td></tr>
</table>

2. **Co-Diseño de Escenarios y Pacto con el Docente:** Previa presentación de la Lista de Chequeo (la cual debe ser enviada a través de la plataforma classroom en la fecha indicada por el docente), el equipo se reunirá con el docente para acordar detalladamente la matriz de comportamiento del muestreo. Se debe pactar qué elementos de la muestra operarán con total eficacia y cuál fallará deliberadamente de forma controlada (Falso Negativo Técnico):
   - 2.1. **Ítems Conformes (Eficacia del Control):** Ustedes construirán y configurarán activamente el entorno correcto en su laboratorio para generar evidencias reales de conformidad. Para declarar un control como **Conforme**, ustedes deben presentar **Evidencia Objetiva Completa**, demostrando el ciclo total del control en tres fases operativas:

     Ejemplo (Control de Acceso e Identidad - MFA):

- **Fase 1: Configuración Operativa (El Botón Encendido):** El equipo muestra en vivo la directiva global de accesos (*IAM, Active Directory o Okta*) donde se evidencia que la muestra de usuarios tiene la política obligatoria de Autenticación de Múltiples Factores (MFA) y una política de bloqueo por intentos fallidos establecida en máximo 3 intentos.
- **Fase 2: Prueba de Fuego (Eficacia Técnica):** Un integrante del equipo simula un ataque de fuerza bruta e intenta iniciar sesión en la consola de la nube introduciendo contraseñas erróneas de forma consecutiva. En la pantalla se debe ver cómo el sistema **frena en seco al atacante, bloquea la cuenta automáticamente** al tercer intento y genera el evento de alerta en el visor de logs centralizado (*SIEM, CloudTrail o Azure Monitor*). El control técnico funciona.
- **Fase 3: Ejecución de Acciones y Evidencia del Plan de Acción,** Aquí es donde demuestran la verdadera gestión institucional. El equipo debe enseñarle al auditor qué pasa *después* de que el log registra los intentos fallidos:
  - **Activación de la Alerta:** Muestran el correo electrónico o la notificación automática en tiempo real que el sistema envió al equipo de Seguridad de la Información (SOC) alertando sobre el bloqueo de la cuenta por intentos fallidos.
  - **Evidencia del Plan de Acción (Tratamiento del Evento):** El equipo presenta el ticket de soporte o el registro de la plataforma de gestión donde se evidencia la ejecución del procedimiento de respuesta: *aislamiento temporal de la IP atacante, verificación de identidad con el usuario real mediante un canal alterno seguro, y la orden de restablecimiento seguro de credenciales*.
  - **Trazabilidad Histórica:** Se exhibe el reporte mensual de indicadores donde la gerencia de TI revisa cuántas cuentas se bloquearon en el mes, qué planes de acción se aplicaron y las firmas digitales que demuestran que el control se gobierna, se mide y tiene mejora continua. **Si hay un registro en el log, debe haber una acción documentada que responda a él. Eso es gestión completa.**

2.2. Ítems Ítems No Conformes (Fallas de Gestión / Riesgos): Ustedes construirán y configurarán activamente el entorno correcto en su laboratorio para generar evidencias reales de NO conformidad. Se seleccionará uno o varios puntos[1] de la lista para que falle de forma técnica, simulando una debilidad real.

Ejemplo Real Empresarial (Falta de Revocación de Accesos a Proveedor Crítico-*Offboarding*):

Imaginen que su equipo está auditando el control de seguridad en las relaciones con proveedores de una empresa. Para demostrar técnicamente una No Conformidad con la contundencia de un auditor internacional, el equipo debe estructurar el hallazgo en tres pasos:

- **Paso 1:** El Cruce de Información (La Línea Base): El equipo de auditores solicita primero el registro oficial de contratos vigentes del área de Compras o Legal. En la pantalla muestran que el contrato del *"Proveedor de Soporte Técnico X"* finalizó formalmente hace 6 meses. Esta es la realidad documental de la empresa.

[1] Previa aprobación del docente.

- **Paso 2:** La Ejecución Técnica (La Prueba de Campo): Sin alterar nada del sistema, los estudiantes abren en vivo las herramientas de auditoría técnica o las consolas de administración (*Active Directory*, consolas cloud *AWS/Azure* o las tablas de usuarios de la VPN). Buscan las credenciales asignadas a los ingenieros de ese ex-proveedor y ejecutan comandos de consulta en directo.
- **Paso 3:** La Evidencia Contundente e Irrefutable (El Dictamen del Hallazgo): En la pantalla se debe visualizar claramente que el estado de esas cuentas sigue figurando como "Active" / "Enabled" (Activo / Habilitado) y que el sistema les sigue permitiendo autenticarse en la red interna. El auditor toma la captura de pantalla del log del sistema que tiene la fecha y hora actual, indexa el reporte técnico exportado y dicta de manera fulminante: *"Se evidencia una No Conformidad Mayor debido a que un tercero ajeno a la organización mantiene accesos vigentes a la infraestructura crítica"*. El auditor cierra su prueba ahí, dejando la evidencia lista y blindada para el informe, sin tocar un solo botón para solucionarlo.

Aclaración: El auditor **JAMÁS propone soluciones, no arregla sistemas, no diseña planes de acción ni le dice a la empresa cómo solucionar el problema**. Si el auditor hiciera eso, perdería su independencia y objetividad. El trabajo del auditor consiste única y exclusivamente en **detectar y documentar de manera contundente e irrefutable la evidencia técnica de la No Conformidad.** Si el sistema está roto, el auditor simplemente demuestra con pruebas irrefutables que está roto.

2.3. **Ítems Oportunidades de Mejora [OM] (Optimización del Control**): Ustedes construirán y configurarán activamente el entorno correcto en su laboratorio para generar evidencias reales de oportunidad de mejora. Se acordará un punto donde el control sí es conforme y cumple, pero su gestión se puede optimizar o automatizar para reducir el riesgo humano y elevar el nivel de madurez.

- **Ejemplo (Gestión de Vulnerabilidades**): Durante la auditoría al control de parches de seguridad, el equipo valida que la empresa es Conforme: los ingenieros revisan manualmente los servidores el primer lunes de cada mes, identifican fallas y aplican las actualizaciones usando comandos de consola. Las evidencias (logs de actualización) demuestran cumplimiento estricto. Sin embargo, la Oportunidad de Mejora consiste en proponer o simular la transición hacia una herramienta de gestión centralizada y automatizada (como AWS Systems Manager Patch Manager o Azure Automation). Esto optimiza el control al eliminar la dependencia de la memoria del ingeniero, reduciendo la ventana de exposición ante vulnerabilidades críticas de semanas a solo horas.

¡Atención! : Un auditor no se conforma con que le muestren una pantalla que diga *"miren, aquí está el log que muestra que alguien falló la contraseña"*. El auditor les preguntará de inmediato: *¿Y qué hizo la empresa al respecto? ¿Cuál fue el plan de acción?*

4. ESTRUCTURA CRONOMÉTRICA DE LA EXPOSICIÓN (DIRECTO AL GRANO)

Queda terminantemente prohibido el uso de exposiciones de índole teórica, lecturas extensas de diapositivas o introducciones conceptuales sobre el significado del control ISO 27001 asignado. El ejercicio arranca directamente en la fase operativa de auditoría técnica.

⚠️ **Nota Operativa Importante:** El cumplimiento del tiempo es un factor crítico en la evaluación. Sin embargo, si por la complejidad técnica de los laboratorios o de las pruebas configuradas el equipo estima que **requiere tiempo adicional, deberá comunicarlo formalmente y con suficiente anticipación al docente** para que este evalúe la viabilidad técnica y pueda ser concedido de manera ordenada.

El tiempo límite es de 60 minutos distribuidos rigurosamente de la siguiente manera:

Bloque 1: Contexto Operativo del Entorno (Máximo 3 minutos)

- El equipo asume inmediatamente el rol de auditor e introduce de forma directa y sin preámbulos el alcance de la sesión, los sistemas o infraestructura a evaluar y la muestra representativa seleccionada. Realizarán una pequeña y concisa introducción técnica al control asignado de la NTC-ISO-IEC 27001:2022 y darán paso inmediato al proceso de auditoría operativa.

Bloque 2: Ejecución Técnica, Evidencia y Dictamen en Vivo (45 a 50 minutos)

- Es el núcleo fundamental de la evaluación. Los estudiantes interactúan directamente con herramientas de software informático (ej.: Nmap, Nessus, OpenVAS, SonarQube, Wireshark, consolas de administración AWS/Azure, directivas de Windows Active Directory, logs del sistema, etc.). El equipo pasará las herramientas sobre los ítems de la muestra pactada y defenderá con criterio técnico los resultados en pantalla. Al finalizar cada prueba o validación, el equipo indicará inmediatamente el panorama del hallazgo encontrado, dictaminando de manera fluida si el ítem es Conforme (Eficaz) o si constituye una No Conformidad u Observación.

Bloque 3: Conclusiones Académicas y Lecciones Aprendidas (Máximo 7 minutos)

- El equipo concluye la sesión quitándose temporalmente el sombrero de auditor para reflexionar abiertamente ante el grupo sobre qué aprendieron y cuál fue el valor real del ejercicio. No se permiten conclusiones genéricas sobre "la importancia de la seguridad". Deben responder con criterio técnico a los siguientes puntos:
  1. **La Brecha Real:** Qué descubrieron al contrastar lo que dice el estándar de la norma en papel frente a la dificultad técnica real de configurarlo y auditarlo en un entorno vivo.
  2. **Complejidad de la Evidencia:** Cuál fue el mayor reto técnico para lograr extraer una evidencia objetiva que fuera verdaderamente contundente e irrefutable
  3. **Madurez Corporativa:** Qué lecciones les deja el ejercicio.

5. MODALIDADES DE PRESENTACIÓN Y SUSTENTACIÓN

A fin de garantizar un alto desempeño técnico y mitigar incidentes fortuitos con los entornos tecnológicos, los equipos de trabajo gozarán de total flexibilidad para seleccionar una de las siguientes dos modalidades de entrega:

1. **Opción A: Grabación de Video Técnica Operativa**
   El equipo graba, edita y produce de forma anticipada un video de acuerdo con el tiempo establecido, donde ejecutan en su totalidad las pruebas informáticas en sus laboratorios de sistemas, garantizando fluidez y tomas detalladas de los logs y herramientas. El día oficial de la exposición se proyectará el material frente a la clase y el docente. Es de carácter obligatorio que al finalizar la proyección, todos los integrantes del equipo se encuentren disponibles en vivo para la sesión de sustentación, defensa técnica y preguntas formuladas por el docente y el grupo. Excepción **Bloque 3.**

2. **Opción B: Exposición Práctica en Vivo y en Directo**
   Presentación en tiempo real. Durante la sesión de clase asignada, compartirán pantalla y ejecutarán los comandos, escaneos de vulnerabilidades, consultas a bases de datos o validaciones de configuraciones cloud en vivo frente a la audiencia. Dispondrán del tiempo establecido bajo estricto cronómetro. Al igual que en la opción anterior, se reserva un espacio final para resolver interrogantes de auditoría.

3. **Opción C: Modalidad Mixta –** Presentación de Evidencias Pregrabadas y Sustentación Técnica en Vivo
   - El equipo podrá combinar las modalidades A y B mediante una exposición técnica en vivo, apoyada en evidencias previamente recopiladas, tales como videos de ejecución de pruebas, capturas de pantalla, fotografías, registros de eventos (logs), resultados de herramientas de auditoría, configuraciones de sistemas y demás soportes técnicos obtenidos durante el proceso de evaluación.
   - Durante la exposición, los estudiantes deberán presentar y explicar en tiempo real cada una de las evidencias seleccionadas, demostrando el procedimiento de auditoría ejecutado, los criterios utilizados para su evaluación y los resultados obtenidos.

GENERALIDADES

Por cada aspecto evaluado, el equipo deberá explicar obligatoriamente:

1. **Control o requisito evaluado**: Identificar el numeral de la norma, requisito legal o criterio de auditoría aplicable.
2. **Objetivo de la verificación:** Explicar qué se pretendía comprobar y por qué era importante.
3. **Procedimiento ejecutado:** Describir cómo se realizó la revisión, qué herramientas se utilizaron y qué pruebas técnicas se aplicaron.
4. **Resultado de la evaluación**: Clasificar y justificar cada aspecto como Conforme (C), No Conforme (NC) u Oportunidad de Mejora (OM), según corresponda.
5. **Evidencia objetiva y justificación técnica del hallazgo:** Presentar las evidencias obtenidas durante la auditoría (fotografías, videos, capturas de pantalla, configuraciones, registros de eventos, resultados de pruebas u otros soportes verificables) y explicar técnicamente qué demuestran, relacionándolas con el requisito o control evaluado. El estudiante deberá justificar, con base en dichas evidencias, por qué el resultado se clasifica como Conforme (C), No Conforme (NC) u Oportunidad de Mejora (OM), demostrando, cuando corresponda, la implementación y eficacia del control.

6. ENTREGABLES OBLIGATORIOS Y CONTENIDO TÉCNICO

Para el desarrollo del Parcial II, cada equipo deberá presentar dos entregables obligatorios:

1. **Registro de Lista de Chequeo,** completamente diligenciada.
2. Presentación y sustentación práctica de la auditoría, en el formato que el equipo considere más adecuado.

1. ENTREGABLE 1. LISTA DE CHEQUEO DE AUDITORÍA EN EXCEL

- La lista de chequeo será el documento principal para registrar la planificación, ejecución y resultados de la auditoría.
- Se utilizará una sola matriz, en la cual cada fila representará una verificación específica.
- Un mismo control podrá aparecer en varias filas cuando se utilicen técnicas, procedimientos o pruebas diferentes.
- No se aceptarán descripciones genéricas como «verificar seguridad», «revisar el sistema» o «ejecutar herramienta» sin explicar el procedimiento.
- Justificación técnica y empresarial: No será suficiente indicar que se seleccionó un activo «porque es importante».
- Las pruebas podrán ejecutarse mediante herramientas informáticas especializadas, siempre que sean pertinentes al control y estén autorizadas.
- No se aceptarán ítems sin procedimiento de verificación, resultados sin evidencia objetiva ni conclusiones sin justificación técnica.
- La ejecución de una herramienta no constituye automáticamente una conformidad o no conformidad. Sus resultados deberán interpretarse y contrastarse con los criterios aplicables.

2. ENTREGABLE 2. PRESENTACIÓN Y SUSTENTACIÓN PRÁCTICA

- Cada equipo podrá seleccionar libremente la forma de presentar su trabajo: diapositivas, ejecución en vivo, grabaciones, diagramas, demostración de herramientas o una combinación de estos recursos.
- La presentación deberá ser principalmente práctica y no una exposición extensa de definiciones teóricas.
- Durante la sustentación, el equipo deberá demostrar:
  1. Contexto y alcance: Qué proceso o entorno se evaluó y qué controles fueron seleccionados.
  2. Muestreo: Cuál era la población, qué elementos se seleccionaron y por qué.
  3. Técnicas de auditoría: Cómo se aplicaron las técnicas de observación, entrevista, revisión documental, prueba u otras pertinentes.
  4. Ejecución técnica: Como mínimo, una prueba controlada con una herramienta especializada relacionada con los controles evaluados.
  5. Evidencias objetivas: Qué documentos, configuraciones, registros o resultados respaldan las conclusiones.
  6. Análisis de resultados: Por qué se asignó cada clasificación presentada y qué evidencia permite sustentarla.
  7. Verificación de eficacia: Qué comprobaciones se realizaron para determinar si los controles funcionan conforme a los criterios establecidos.
  8. Conclusiones: Cuáles fueron los principales resultados y qué limitaciones presenta la evaluación.
  9. Sustentación individual: Todos los integrantes deberán demostrar dominio del trabajo completo.

Condiciones de la exposición

- Las pruebas deberán ejecutarse en entornos autorizados y sin comprometer sistemas productivos, información real o servicios de terceros.
- Los escenarios de laboratorio podrán prepararse previamente, pero las conclusiones de auditoría deberán sustentarse en las verificaciones efectivamente realizadas.
- No se exigirá un informe adicional ni un expediente independiente de papeles de trabajo. Las evidencias deberán estar referenciadas en la matriz y disponibles para su demostración durante la exposición.

Criterio fundamental de evaluación

Por cada verificación realizada, el estudiante deberá estar en capacidad de responder:
¿Qué control estoy evaluando?
¿Qué requisito debe cumplirse?
¿Qué elemento de la muestra seleccioné y por qué?
¿Qué técnica de auditoría utilicé?
¿Qué procedimiento ejecuté?
¿Qué herramienta utilicé, cuando correspondía?
¿Qué evidencia objetiva obtuve?
¿Qué demuestra esa evidencia?
¿Pude verificar el funcionamiento o la eficacia del control?
¿Cuál es mi conclusión y cómo la sustento?

La calificación no dependerá de la cantidad de herramientas ejecutadas ni del número de capturas presentadas, sino de la pertinencia de las verificaciones, la calidad de las evidencias y la capacidad del estudiante para sustentar técnicamente sus conclusiones.

7. ALGUNAS FUENTES TÉCNICAS Y METODOLOGÍAS APLICADAS A ISO/IEC 27001:2022

1. Seguridad en el Desarrollo de Software (Control A.8.32 - Gestión de ciclo de vida seguro)
Cuando el equipo audite entornos de programación, no basta con citar ISO 27001. Sus listas de chequeo deben basarse en: [1]

- **Metodología OWASP (Open Web Application Security Project):** Específicamente el OWASP Top 10 (para auditoría de vulnerabilidades en aplicaciones web), OWASP ASVS (Application Security Verification Standard) para niveles de requisitos de seguridad en pruebas de penetración, y OWASP SAMM (Software Assurance Maturity Model) para auditar la madurez del ciclo de vida del desarrollo. [1]
- **NIST SP 800-218 (SSDF - Secure Software Development Framework):** La metodología estándar del gobierno de EE.UU. para auditar las prácticas seguras en la cadena de suministro y creación de código fuente.

2. Seguridad en Redes y Telecomunicaciones (Controles A.8.20 y A.8.21)
Para evaluar la infraestructura física, topológica y perimetral de conectividad, se deben contrastar las configuraciones contra:

- **Familia ISO/IEC 27033 (Partes 1 a 6):** Es la guía estándar internacional e hija de la ISO 27001 dedicada exclusivamente a la seguridad en redes (diseño, pasarelas de seguridad, VPNs y comunicaciones inalámbricas).
- **Normas TIA/EIA 568 (A y B) y TIA 942:** Estándares mundiales para auditar el cableado estructurado, la disposición física de los racks, etiquetado de cables, redundancia de energía y diseño de Centros de Datos (Data Centers).

3. Configuraciones Seguras y Hardening (Control A.8.9 - Configuración de seguridad)
El auditor experto no solo mira si hay un firewall; valida que los sistemas operativos y bases de datos estén "endurecidos" frente a ataques. [1]

- **CIS Benchmarks (Center for Internet Security):** Es la fuente de consulta técnica por excelencia en auditorías operativas. Los estudiantes deben usar las guías de configuración segura de CIS Benchmarks para auditar sistemas específicos en vivo (ej. *CIS Benchmark para Windows Server, CIS Benchmark para AWS de Amazon o Docker*). [1, 2]

4. Gestión de Vulnerabilidades Técnicas (Control A.8.8 - Gestión de vulnerabilidades técnicas)
Para validar cómo la empresa descubre y evalúa los fallos en sus sistemas: [1]

- **Estándar CVE (Common Vulnerabilities and Exposures) y CVSS (Common Vulnerability Scoring System):** El método internacional para clasificar el nivel de criticidad (de 0.0 a 10.0) de los hallazgos técnicos que arrojen herramientas como *Nessus, OpenVAS o Qualys* durante la exposición.
- **NIST SP 800-40 (Guide to Enterprise Patch Management):** La metodología para auditar el ciclo de vida completo de la instalación de parches de seguridad en la empresa.

5. Gestión de Logs, Monitoreo y Eventos (Controles A.8.15 y A.8.16)
Para auditar la fase en donde el estudiante simula rastrear e identificar ataques en vivo mediante registros del sistema:

- **NIST SP 800-92 (Guide to Computer Security Log Management):** La guía metodológica principal para estructurar un checklist sobre retención de logs, análisis de

pistas de auditoría y protección de los archivos de registro para que no sean borrados por un atacante.

6. Seguridad en la Nube / Cloud Computing (Control A.5.23 - Seguridad de la información para el uso de servicios en la nube)
Uno de los controles nuevos más importantes de la versión 2022 de la norma. Si el laboratorio del equipo simula entornos como Azure, AWS o GCP, deben fundamentarse en: [1]

- **ISO/IEC 27017 e ISO/IEC 27018:** Normas específicas que complementan a la ISO 27001 añadiendo controles puntuales para la seguridad en la nube y la protección de datos personales (PII) en entornos cloud públicos.
- **CSA CCM (Cloud Security Alliance - Cloud Controls Matrix):** La metodología y hoja de ruta más respetada a nivel corporativo para auditar la gobernanza, interoperabilidad y seguridad técnica de proveedores y entornos en la nube.

Cómo debe verse la bibliografía técnica en la Lista de Chequeo del Estudiante
Para asegurar que apliquen esto correctamente, exígeles que cada pregunta o ítem técnico de verificación de su documento esté obligatoriamente amarrado tanto al control de la **ISO 27001:2022** como a su fuente metodológica de campo.

8. RÚBRICA DETALLADA DE EVALUACIÓN (MÁXIMO 100 PUNTOS)

Criterio de Evaluación	Descripción	Puntaje Máximo
Ejecución Técnica y Defensa de la Eficacia (65%)	• Operación fluida y profesional de herramientas informáticas de auditoría y ciberseguridad en pantalla (sin improvisaciones). • Sustentación y defensa de los criterios técnicos: el alumno demuestra con propiedad absoluta por qué un log, reporte o parámetro en pantalla valida que el control es Conforme (Eficaz), No Conforme u oportunidad de mejora frente a los requerimientos de la NTC-ISO-IEC 27001:2022. • Aplicación rigurosa del muestreo técnico previamente acordado con el docente.	**70 Puntos**
Lista de Chequeo e Indexación de Hallazgos (20%)	• Calidad, estructura formal y rigurosidad técnica de la Lista de Chequeo entregada en los plazos fijados de forma obligatoria (un día antes de las exposiciones). • Fundamentación del documento en fuentes bibliográficas oficiales, metodologías globales de auditoría (ej.: COBIT, ISO 27002, NIST, OWASP, ISO 22301) o buenas prácticas técnicas verificables. • Clasificación lógica de las evidencias técnicas recolectadas durante las pruebas.	**20 Puntos**
Claridad, Coherencia Operativa y Tiempo (15%)	• Enfoque de exposición 100% pragmático, ágil y directo al grano, eludiendo rodeos conceptuales o marcos teóricos innecesarios. • Control impecable de los tiempos (máximo 40 minutos en total para la simulación operativa). • Utilización fluida de un vocabulario técnico especializado idóneo para un Auditor de Seguridad de la Información.	**10 Puntos**